

Explicación del Módulo: Fuerza Bruta Web

`bruteforce_web.py`

Suite de Auditoría de Seguridad Informática

24 de mayo de 2026

Introducción

El módulo `bruteforce_web.py` (asignado al Grupo 4 para la Fase II) automatiza un ataque de **Fuerza Bruta contra formularios de inicio de sesión web** (como los de una red social, un banco o un panel de administración). A diferencia del protocolo FTP, la web (HTTP) requiere que el script simule el comportamiento de un navegador enviando los datos a través de una petición `POST`.

¿Cómo funciona el código paso a paso?

1. **Configuración Inicial (Parámetros Clave):** Para que el ataque funcione, el script necesita saber tres cosas:
 - `target_url`: La dirección exacta donde se procesa el formulario (ej. *`http://sitio.com/login.php`*).
 - `login_data_template`: Un diccionario o 'plantilla' que imita los campos del formulario HTML original (ej. los campos *`username`* y *`password`*).
 - `success_indicator`: Una palabra o frase que el servidor web solo muestra cuando el inicio de sesión es exitoso (ej. *`'Bienvenido al panel'`* o *`'Cerrar sesión'`*).
2. **Generación de Combinaciones:** Al igual que en otros módulos de fuerza bruta, el método `load_dictionaries` cruza listas de usuarios y contraseñas, generando todas las combinaciones posibles y almacenándolas en una cola (`queue.Queue`).
3. **El Trabajador y las Peticiones (`_worker`):** Múltiples hilos (trabajadores concurrentes) toman combinaciones de la cola de manera simultánea. En cada intento:
 - El hilo hace una copia de la plantilla (`login_data_template`) y rellena los campos con el usuario y la contraseña actuales.
 - Utiliza la librería `requests` para enviar esta información al servidor (`requests.post`).
 - El servidor responde con el código fuente HTML de la página resultante.
4. **Validación del Éxito:** Dado que HTTP es un protocolo sin estado, un código de respuesta 200 (OK) no significa necesariamente que ingresamos correctamente, solo que la página cargó. Por ello, el script busca el `success_indicator` dentro del texto de la respuesta (`response.text`). Si lo encuentra, ¡bingo!, guarda las credenciales y detiene a los demás hilos mediante el `stop_event`.

Estructura de Salida e Integración

El script retorna una lista cruda con las credenciales válidas encontradas. Como el Grupo 4 también es el responsable de la orquestación principal (`auditoria.py`), deberá asegurarse de que la función que llame a este módulo formatee la respuesta final para que cumpla estrictamente con el contrato del proyecto (`schema_resultados.json`).

Conclusión

Este módulo resalta la importancia de proteger los formularios web no solo con contraseñas fuertes, sino también implementando mecanismos de defensa contra la automatización, tales como CAPTCHAs, bloqueos temporales tras intentos fallidos (rate-limiting) o autenticación multifactor (MFA).